Public: Statement of Applicability (ISO 27001:2022, ISO27701, ISO27018, ISO27017)



Owned by Susan Phillips
Just a moment ago • 27 min read • Analytics

1. Purpose

The purpose of this document is to define which controls are appropriate to be implemented at BigCommerce, the objectives of these controls and how they are implemented, as well as to approve residual risks and formally approve the implementation of said controls.

2. Scope

This document includes all controls listed in Annex A of the ISO 27001 standard. Controls are applicable to the entire Information Security Management System (ISMS).

3. Definitions and Related Documents

- ISO/IEC 27001:2022, Information technology — Security techniques — Information security management systems — Requirements, Clause 6.1.3
- The information security controls listed in Table 4.1 are directly derived from and aligned with those listed in ISO/IEC 27002:2022[1], Clauses 5 to 8, and shall be used in context with 6.1.3.
- ISO/IEC 27701:2019 Privacy Information Management
- ISO/IEC 27018:2019 Code of practice for protection of personally identifiable information (PII) in public clouds acting as PII processors
- ISO/IEC 27017:2015 Code of practice for information security controls based on ISO/IEC 27002 for cloud services

4. Applicability of Controls

4.1 ISO 27001:2022 Annex A Controls - Information Security Controls

Control ID	Control Group Name/Control Name	Applicability (Yes/No)	Justification for non-applicability	Control
A5	**Organizational Controls**			

A5.1	Policies for Information Security	Yes	N/A	Information security policy and topic-specific polic published, communicated to and acknowledged by

A5.2	Information security roles and responsibilities	Yes	N/A	Information security roles and responsibilities
A5.3	Segregation of duties	Yes	N/A	Conflicting duties and conflicting areas of respons
A5.4	Management responsibilities	Yes	N/A	Management shall require all personnel to apply in established information security policy, topic-spec
A5.5	Contact with authorities	Yes	N/A	The organization shall establish and maintain conta
A5.6	Contact with special interest groups	Yes	N/A	The organization shall establish and maintain conta security forums and professional associations.
A5.7	Threat intelligence	Yes	N/A	Information relating to information security threats intelligence.
A5.8	Information security in project management	Yes	N/A	Information security shall be integrated into projec
A5.9	Inventory of information and other associated assets	Yes	N/A	An inventory of information and other associated a maintained.
A5.10	Acceptable use of information and other associated assets	Yes	N/A	Rules for the acceptable use and procedures for ha shall be identified, documented and implemented.
A5.11	Return of assets	Yes	N/A	Personnel and other interested parties as appropri possession upon change or termination of their em
A5.12	Classification of information	Yes	N/A	Information shall be classified according to the info on confidentiality, integrity, availability and relevant
A5.13	Labelling of information	Yes	N/A	An appropriate set of procedures for information la accordance with the information classification sch
A5.14	Information transfer	Yes	N/A	Information transfer rules, procedures, or agreeme facilities within the organization and between the o
A5.15	Access control	Yes	N/A	Rules to control physical and logical access to info established and implemented based on business a
A5.16	Identity management	Yes	N/A	The full life cycle of identities shall be managed.

A5.17	Authentication information	Yes	N/A	Allocation and management of authentication infor process, including advising personnel on appropria
A5.18				and removed in accordance with the organization's control.
A5.19	Information security in supplier relationships	Yes	N/A	Processes and procedures shall be defined and im risks associated with the use of supplier's product
A5.20	Addressing information security within supplier agreements	Yes	N/A	Relevant information security requirements shall b on the type of supplier relationship.
A5.21	Managing information security in the **information and communication technology** (ICT) supply chain	Yes	N/A	Processes and procedures shall be defined and im risks associated with the ICT products and service
A5.22	Monitoring, review and change management of supplier services	Yes	N/A	The organization shall regularly monitor, review, ev security practices and service delivery.
A5.23	Information security for use of cloud services	Yes	N/A	Processes for acquisition, use, management and e accordance with the organization's information sec
A5.24	Information security incident management planning and preparation	Yes	N/A	The organization shall plan and prepare for manag establishing and communicating information secur responsibilities.
A5.25	Assessment and decision on information security events	Yes	N/A	The organization shall assess information security information security incidents.
A5.26	Response to information security incidents	Yes	N/A	Information security incidents shall be responded t procedures.
A5.27	Learning from information security incidents	Yes	N/A	Knowledge gained from information security incide information security controls.
A5.28	Collection of evidence	Yes	N/A	The organization shall establish and implement pro acquisition and preservation of evidence related to
A5.29	Information security during disruption	Yes	N/A	The organization shall plan how to maintain inform disruption.

A5.30	ICT readiness for business continuity	Yes	N/A	ICT readiness shall be planned, implemented, mair objectives and ICT continuity requirements.
A5.31	and contractual requirements			organization's approach to meet these requiremen date.
A5.32	Intellectual property rights	Yes	N/A	The organization shall implement appropriate proc
A5.33	Protection of records	Yes	N/A	Records shall be protected from loss, destruction, unauthorized release.
A5.34	Privacy and protection of personal identifiable information (PII)	Yes	N/A	The organization shall identify and meet the requir protection of PII according to applicable laws and r
A5.35	Independent review of information security	Yes	N/A	The organization's approach to managing informat people, processes and technologies shall be revie intervals, or when significant changes occur.
A5.36	Compliance with policies, rules and standards for information security	Yes	N/A	Compliance with the organization's information sec standards shall be regularly reviewed.
A5.37	Documented operating procedures	Yes	N/A	Operating procedures for information processing f to personnel who need them.
A6	**People Controls**	**Applicability (Yes/No)**	**Justification for non-applicability**	**Control**
A6.1	Screening	Yes	N/A	Background verification checks on all candidates t joining the organization and on an ongoing basis ta regulations and ethics and be proportional to the b information to be accessed and the perceived risks
A6.2	Terms and conditions of employment	Yes	N/A	The employment contractual agreements shall sta responsibilities for information security.
A6.3	Information security awareness, education and training	Yes	N/A	Personnel of the organization and relevant interest security awareness, education and training and reg security policy, topic-specific policies and procedu
A6.4	Disciplinary process	Yes	N/A	A disciplinary process shall be formalized and com other relevant interested parties who have commit

A6.5	Responsibilities after termination or change of	Yes	N/A	Information security responsibilities and duties tha employment shall be defined, enforced and comm

A6.6	Confidentiality or non-disclosure agreements	Yes	N/A	Confidentiality or non-disclosure agreements refle of information shall be identified, documented, reg other relevant interested parties.
A6.7	Remote working	Yes	N/A	Security measures shall be implemented when per information accessed, processed or stored outside
A6.8	Information security event reporting	Yes	N/A	The organization shall provide a mechanism for pe information security events through appropriate ch
A7	**Physical Controls**	**Applicability (Yes/No)**	**Justification for non-applicability**	**Control**
A7.1	Physical security perimeters	Yes	N/A	Security perimeters shall be defined and used to p associated assets.
A7.2	Physical entry	Yes	N/A	Secure areas shall be protected by appropriate ent
A7.3	Securing offices, rooms and facilities	Yes	N/A	Physical security for offices, rooms and facilities sh
A7.4	Physical security monitoring	Yes	N/A	Premises shall be continuously monitored for unau
A7.5	Protecting against physical and environmental threats	Yes	N/A	Protection against physical and environmental thre intentional or unintentional physical threats to infra
A7.6	Working in secure areas	Yes	N/A	Security measures for working in secure areas sha
A7.7	Clear desk and clear screen	Yes	N/A	Clear desk rules for papers and removable storage processing facilities shall be defined and appropria
A7.8	Equipment siting and protection	Yes	N/A	Equipment shall be sited securely and protected.
A7.9	Security of assets off-premises	Yes	N/A	Off-site assets shall be protected.
A7.10	Storage media	Yes	N/A	Storage media shall be managed through their life disposal in accordance with the organization's clas

A7.11	Supporting utilities	Yes	N/A	Information processing facilities shall be protected by failures in supporting utilities.
A7.12				interference or damage.
A7.13	Equipment maintenance	Yes	N/A	Equipment shall be maintained correctly to ensure information.
A7.14	Secure disposal or re-use of equipment	Yes	N/A	Items of equipment containing storage media shall licensed software has been removed or securely o
A8	**Technology Controls**	**Applicability (Yes/No)**	**Justification for non-applicability**	**Control**
A8.1	User end point devices (covers all user endpoint devices such as laptops, tablets and mobile phones)	Yes	N/A	Information stored on, processed by or accessible https://bigcommercecloud.atlassian.net/wiki/space https://bigcommercecloud.atlassian.net/wiki/space https://bigcommercecloud.atlassian.net/wiki/space https://bigcommercecloud.atlassian.net/wiki/space
A8.2	Privileged access rights	Yes	N/A	The allocation and use of privileged access rights s https://bigcommercecloud.atlassian.net/wiki/space • Cloudflare VPN - OKTA SSO/MFA ◦ configuration settings (password/lockout) ◦ GRC-6956 • Viscosity VPN - DUO MFA ◦ configuration settings (password/lockout) • FIM for monitoring • PR Review Quarterly ◦ see A8.8 • Branch Protections Review Quarterly ◦ see A8.8
A8.3	Information access restriction	Yes	N/A	Access to information and other associated assets established topic-specific policy on access contro https://bigcommercecloud.atlassian.net/wiki/space

A8.4	Access to source code	Yes	N/A	Read and write access to sou https://bigcommercecloud.atlassian.net/wiki/space
A8.5	Secure authentication	Yes	N/A	Secure authentication technologies and procedure access restrictions and the topic-specific policy or https://bigcommercecloud.atlassian.net/wiki/space 6.3.2.6 Automatic Account Lockout for Invalid Atte Demo - Sailpoint Evidence of completion of UARs for GCP for Q3 & GRC-5982 GRC-Q3 already submitted
A8.6	Capacity management	Yes	N/A	The use of resources shall be monitored and adjus requirements. https://bigcommercecloud.atlassian.net/wiki/space https://bigcommercecloud.atlassian.net/wiki/space https://bigcommercecloud.atlassian.net/wiki/space https://bigcommercecloud.atlassian.net/wiki/space https://docs.google.com/spreadsheets/d/1c61K- 3mP1UDx1mtokB_yeu5kcFluRyY5rz1UhJQKcVs/ed Demo of Grafana
A8.7	Protection against malware	Yes	N/A	Protection against malware shall be implemented a https://bigcommercecloud.atlassian.net/wiki/space Appendix C Demo of SentinalOne running on our laptop

				Show 'agent details' Need central anti-virus configuration settings - to https://github.com/search?q=repo%3Abigcommer
A8.8	Management of technical vulnerabilities	Yes	N/A	Information about technical vulnerabilities of inforr organization's exposure to such vulnerabilities sha taken. https://bigcommercecloud.atlassian.net/wiki/space 1. Purpose https://docs.google.com/spreadsheets/d/1_Z6WQF /edit#gid=0 MegaplanIT https://bigcommercecloud.atlassian.net/wiki/space AL+scanned+findings+Low+risk https://bigcommercecloud.atlassian.net/wiki/space AL+scanned+findings
A8.9	Configuration management	Yes	N/A	Configurations, including security configurations, c be established, documented, implemented, monitc https://bigcommercecloud.atlassian.net/wiki/space PR Review: https://docs.google.com/spreadsheets/d/1spbH_x4 dit#gid=896887067 Branch Protections Review: https://docs.google.com/spreadsheets/d/1psTFNW DLSvLaPlzl44sg/edit#gid=1164301343 hardening example: https://github.com/search?q=repo%3Abigcommerc platform%20deny&type=code
A8.10	Information deletion	Yes	N/A	Information stored in information systems, devices when no longer required.

				https://bc-eng-docs.herokuapp.com/domains/payr cleanup.html

				https://bigcommercecloud.atlassian.net/wiki/space
A8.11	Data masking	Yes	N/A	Data masking shall be used in accordance with the control and other related topic-specific policies, ar legislation into consideration. https://bigcommercecloud.atlassian.net/wiki/space 4.7 Data Masking https://bigcommercecloud.atlassian.net/wiki/space Demo: login to the BigCommerce Store screenshot of how the first 6 and last 4 characters
A8.12	Data leakage prevention	Yes	N/A	Data leakage prevention measures shall be applied process, store or transmit sensitive information. https://bigcommercecloud.atlassian.net/wiki/space 4.8 Data Leakage Firewalls: Google FIrewalls & Meraki Firewalls
A8.13	Information backup	Yes	N/A	Backup copies of information, software and systen accordance with the agreed topic-specific policy c https://bigcommercecloud.atlassian.net/wiki/space CSS team routinely restores single merchant DB's Backup restoration tests done annually - restores a
A8.14	Redundancy of information processing facilities	Yes	N/A	Information processing facilities shall be implemen requirements. https://bigcommercecloud.atlassian.net/wiki/space 4.8 Redundancy need screenshot of GCP showing redundancy thro
A8.15	Logging	Yes	N/A	Logs that record activities, exceptions, faults and c protected and analysed. https://bigcommercecloud.atlassian.net/wiki/space

				4.8 Event Makeup
A8.16				https://bigcommercecloud.atlassian.net/wiki/space 4.10 Monitoring Need screenshot of Sysdig - set up to ingest logs Demo: show Sumo Logic
A8.17	Clock synchronization	Yes	N/A	The clocks of information processing systems use approved time sources. https://bigcommercecloud.atlassian.net/wiki/space **4.3.11.2 Clock Synchronization** Need screenshot to verify our use of GCP NTP
A8.18	Use of privileged utility programs	Yes	N/A	The use of utility programs that can be capable of be restricted and tightly controlled. https://bigcommercecloud.atlassian.net/wiki/space **4.3.6.5 Use of privileged utility programs**
A8.19	Installation of software on operational systems	Yes	N/A	Procedures and measures shall be implemented to operational systems. https://bigcommercecloud.atlassian.net/wiki/space **4.13.21 Administrator's operational securit** Approved S/W list All s/w is not approved by default until approved, a
A8.20	Networks security	Yes	N/A	Networks and network devices shall be secured, m systems and applications. https://bigcommercecloud.atlassian.net/wiki/space Terraform example:

				https://github.com/search?q=repo%3Abigcommerc platform%20deny&type=code
A8.21	GRC (Governance... / Information Security, ... / Public: Statement of Applicability (IS...			identified, implemented and monitored.https://bigcommercecloud.atlassian.net/ https://bigcommercecloud.atlassian.net/wiki/space 4. Policy/Procedure/Statement
A8.22	Segregation of networks	Yes	N/A	Groups of information services, users and informat organization's networks. https://bigcommercecloud.atlassian.net/wiki/space 4.4 Requirement for Firewalls and DMZs
A8.23	Web filtering	Yes	N/A	Access to external websites shall be managed to r https://bigcommercecloud.atlassian.net/wiki/space 4.3 Web Filtering Cloudflare
A8.24	Use of cryptography	Yes	N/A	Rules for the effective use of cryptography, includi defined and implemented. https://bigcommercecloud.atlassian.net/wiki/space AES256 encryption at rest - proof https://www.ssllabs.com/ssltest/analyze.html?d=m
A8.25	Secure development life cycle	Yes	N/A	Rules for the secure development of software and https://bigcommercecloud.atlassian.net/wiki/space https://bigcommercecloud.atlassian.net/wiki/space
A8.26	Application security requirements	Yes	N/A	Information security requirements shall be identifie acquiring applications. https://bigcommercecloud.atlassian.net/wiki/space https://bigcommercecloud.atlassian.net/wiki/space

A8.27	Secure system architecture and engineering principles	Yes	N/A	Principles for engineering secure systems shall be to any information system development activities.

				https://bigcommercecloud.atlassian.net/wiki/space
A8.28	Secure coding	Yes	N/A	Secure coding principles shall be applied to softwa https://bigcommercecloud.atlassian.net/wiki/space https://bigcommercecloud.atlassian.net/wiki/space
A8.29	Security testing in development and acceptance	Yes	N/A	Security testing processes shall be defined and im https://bigcommercecloud.atlassian.net/wiki/space https://bigcommercecloud.atlassian.net/wiki/space
A8.30	Outsourced development	Yes	N/A	The organization shall direct, monitor and review tl development. https://bigcommercecloud.atlassian.net/wiki/space Outsourced Development
A8.31	Separation of development, test and production environments	Yes	N/A	Development, testing and production environment https://bigcommercecloud.atlassian.net/wiki/space 6.2.3 Separation of Duties
A8.32	Change management	Yes	N/A	Changes to information processing facilities and in management procedures. https://bigcommercecloud.atlassian.net/wiki/space https://bigcommercecloud.atlassian.net/wiki/space https://bigcommercecloud.atlassian.net/wiki/space Need screenshot of VPCs in Google Cloud Consol Need results of recent network segmentation test
A8.33	Test information	Yes	N/A	Test information shall be appropriately selected, pı https://bigcommercecloud.atlassian.net/wiki/space Guiding Principles

				Emergency Change need example of dummy data
A8.34	systems during audit testing			planned and agreed between the tester and appro https://bigcommercecloud.atlassian.net/wiki/space

Annex B - PIMS-specific reference control objectives and controls (PII Processors) - These controls ARE in scope

A.8.2	Conditions for collection and processing	Applicability (Yes/No)	Justification for non-applicability	Control
B.8.2.1	Customer agreement	YES	N/A	The organization shall ensure, where relevant, that process PII addresses the organization's role in pro with the customer's obligations, (taking into accou processing and the information available to the org
B.8.2.2	Organization's purposes	YES	N/A	The organization shall ensure that PII processed or tomer are only processed for the purposes expres mented instructions of the customer.
B.8.2.3	Marketing and advertising use	YES	N/A	The organization shall not use PII processed under purposes of marketing and advertising without est prior consent was obtained from the appropriate P organization shall not make providing such consen receiving the service.
B.8.2.4	Infringing instruction	YES	N/A	The organization shall not use PII processed under purposes of marketing and advertising without est prior consent was obtained from the appropriate P organization shall not make providing such consen receiving the service.
B.8.2.5	Customer obligations	YES	N/A	The organization shall provide the customer with th information such that the customer can demonstra with their obligations.
B.8.2.6	Records related to processing PII	YES	N/A	The organization shall determine and maintain the cords in support of demonstrating compliance with

				(as specified in the applicable contract) for the prc carried out on behalf of a customer.
A.8.3	GRC (Governance... / Information Security, ... / Public: Statement of Applicability (IS...			
B.8.3.1	Obligations to PII principals	YES	YES	The organization shall provide the customer with tl ply with its obligations related to PII principals.
A.8.4	**Privacy by design and privacy by default**	**Applicability (Yes/No)**	**Justification for non-applicability**	**Control**
B.8.4.1	Temporary files	YES	N/A	The organization shall ensure that temporary files a result of the processing of PII are disposed of (e. destroyed) following documented procedures with documented period.
B.8.4.2	Return, transfer or disposal of PII	YES	N/A	The organization shall provide the ability to return, disposal of PII in a secure manner. It shall also mak ble to the customer.
B.8.4.3	PII transmission controls	YES	N/A	The organization shall subject PII transmitted over sion network to appropriate controls designed to e data reaches its intended destination.
A.8.5	**PII sharing, transfer, and disclosure**	**Applicability (Yes/No)**	**Justification for non-applicability**	**Control**
B.8.5.1	Basis for PII transfer between jurisdictions	YES	N/A	The organization shall inform the customer in a tim the basis for PII transfers between jurisdictions and changes in this regard, so that the customer has th to such changes or to terminate the contract.
B.8.5.2	Countries and international organizations to which PII can be transferred	YES	N/A	The organization shall specify and document the c national organizations to which PII can possibly be
B.8.5.3	Records of PII disclosure to third parties	YES	N/A	The organization shall record disclosures of PII to t including what PII has been disclosed, to whom an
B.8.5.4	Notification of PII disclosure requests	YES	N/A	The organization shall notify the customer of any le requests for disclosure of PII.

B.8.5.5	Legally binding PII disclosures	YES	N/A	The organization shall reject any requests for PII di are not legally binding, consult the corresponding customer.
B.8.5.6	Disclosure of subcontractors used to process PII	YES	N/A	The organization shall disclose any use of subcont PII to the customer before use.
B.8.5.7	Engagement of a subcontractor to process PII	YES	N/A	The organization shall only engage a subcontracto according to the customer contract.
B.8.5.8	Change of subcontractor to process PII	YES	N/A	The organization shall, in the case of having gener ization, inform the customer of any intended chang addition or replacement of subcontractors to proc giving the customer the opportunity to object to su

GRC (Governance... / Information Security, ... / Public: Statement of Applicability (IS...

ISO27018 Annex A Controls

A.2	Context and Choice	Applicability (Yes/No)	Justification for non-applicability	Control
A.2.1	Obligation to co-operate regarding PII principals' rights	YES	N/A	The public cloud PII processor should provide the them to fulfil their obligation to facilitate the exerci and/or ,erase PII pertaining to them. **Public cloud PII protection implementation guid** The PII controller's obligations in this respect can b These obligations can include matters where the c public cloud PII processor for implementation. For examp in a timely fashion. Where the PII controller depend or technical measures to facilitate the exercise of P technical measures should ,be specified in the con
A.3	**Purpose legitimacy and specification**	**Applicability (Yes/No)**	**Justification for non-applicability**	**Control**
A.3.1	Public cloud PII processor's purpose	YES	N/A	PII to be processed under a contract should not be instructions of the cloud service customer.

				Public cloud PII protection implementation guid to achieve the cloud service customer's purpose, t appropriate for a public cloud PII processor to dete with the general instructions of the cloud service c express instruction. For example, in order to efficie be necessary to allocate specific processing resou PII principal. In circumstances where the public clo processing method involves the collection and use adhere to the relevant privacy principles set forth i should provide the cloud service customer with all the cloud service customer to ensure the public cl specification and limitation principles and ensure t processor or any of its sub-contractors for further cloud service customer.
A.3.2	Public cloud PII processor's commercial use	YES	N/A	PII processed under a contract should not be used purposes of marketing and advertising without exp condition of receiving the service. NOTE This control is an addition to the more gener otherwise supersede it.
A.5	**Data Minimization**	**Applicability (Yes/No)**	**Justification for non-applicability**	**Control**
A.5.1	Secure erasure of temporary files	YES	N/A	Temporary files and documents should be erased period. **Public cloud PII protection implementation guid** Implementation guidance on PII erasure is provide Information systems can create temporary files in t specific to the system or application, but can inclu files associated with the updating of databases and the Temporary files are not needed after the related in there are circumstances in which they may not be deleted. T use is not always deterministic but a "garbage coll and

				determine how long it has been since they were las implement a periodic check that unused temporary
A.6	GRC (Governance... / Information Security, ... / Public: Statement of Applicability (IS...			
	disclosure limitation		**applicability**	
A.6.1	PII disclosure notification	YES	N/A	The contract between the public cloud PII process the public cloud PII processor to notify the cloud s procedure and time periods agreed in the contract by a law enforcement authority, unless such a disc **Public cloud PII protection implementation guid** The public cloud PII processor should provide cont — reject any requests for PII disclosure that are no — consult the corresponding cloud service custom disclosure; and — accept any contractually agreed requests for PII corresponding cloud service customer. EXAMPLE A possible prohibition on disclosure wou the confidentiality of a law enforcement investigati
A.6.2	Recording of PII disclosures	YES	N/A	Disclosures of PII to third parties should be record whom and at what time. **Public cloud PII protection implementation guid** PII can be disclosed during the course of normal o (see12.4.1). Any additional disclosures to third part investigations or external audits, should also be recorded. The reco and the source of the authority to make the disclos
A.8	**Openness, transparency and notice**	**Applicability (Yes/No)**	**Justification for non-applicability**	**Control**
A.8.1	Disclosure of sub-contracted PII processing	YES	N/A	The use of sub-contractors by the public cloud PII the relevant cloud service customers before their u guidance Provisions for the use of sub-contractors contract between the public cloud PII processor ar should specify that sub- contractors can only be c generally be given by the cloud service customer a

				PII processor should inform the cloud service custo in this regard so that the cloud service customer h

				disclosed should also include the countries in whic and the means by which sub-contractors are obliged to meet or exceed the obli A.11.12). Where public disclosure of sub-contracto beyond acceptable limits, disclosure should be ma the request of the cloud service customer. The clo the information is available.
A.10	**Accountability**	**Applicability (Yes/No)**	**Justification for non-applicability**	**Control**
A.10.1	Notification of a data breach involving PII	YES	N/A	The public cloud PII processor should promptly no event of any unauthorized access to PII or unautho resulting in loss, disclosure or alteration of PII. **Public cloud PII protection implementation guid** Provisions covering the notification of a data breac between the public cloud PII processor and the clo how the public cloud PII processor will provide the customer to fulfil his obligation to notify relevant au extend to a data breach caused by the cloud servic components for which they are responsible. The c notification of a data breach involving PII. In the ev record should be maintained with a description of the incident, the name of the reporter, to whom the the incident (including the person in charge and th resulted in loss, disclosure or alteration of PII. In th occurred, the record should also include a descrip notifications were performed, the steps taken to n agencies. In some jurisdictions, relevant legislation processor to directly notify appropriate regulatory data breach involving PII. NOTE There can be other breaches requiring notifi without consent or other authorization, use for una
A.10.2	Retention period for administrative security policies	YES	N/A	Copies of security policies and operating procedur period on replacement (including updating).

	and guidelines			**Public cloud PII protection implementation guid**

				period of five years is recommended in the absenc
A.10.3	PII return, transfer and disposal	YES	N/A	The public cloud PII processor should have a policy of PII and should make this policy available to the c **Public cloud PII protection implementation guid** At some point in time, PII can need to be disposed PII to the cloud service customer, transferring it to controller(e.g. as a result of a merger), securely de archiving it. The public cloud PII processor should cloud service customer to ensure that PII processe PII processor and any of its sub-contractors) from purposes of backup and business continuity, as so specific purposes of the cloud service customer. T linking, overwriting, demagnetization, destruction commercial standards should be provided for cont develop and implement a policy in respect of the d available to cloud service customer. The policy sho destruction after termination of a contract, to prote through an accidental lapse of the contract. NOTE This control and guidance is also relevant ur and disclosure limitation" principle (see A.6).
A.11	**Information Security**	**Applicability (Yes/No)**	**Justification for non-applicability**	**Control**
A.11.1	Confidentiality or non-disclosure agreements	YES	N/A	Individuals under the public cloud PII processor's c confidentiality obligation. **Public cloud PII protection implementation guid** A confidentiality agreement, in whatever form, bet and its agents should ensure that employees and a independent of the instructions of the cloud service customer (agreement should survive termination of any releva

A.11.2	Restriction of the creation of hardcopy material	YES	N/A	The creation of hardcopy material displaying PII sh
A.11.3	Control and logging of data restoration	YES	N/A	There should be a procedure for, and a log of, data **Public cloud PII protection implementation guid** NOTE The above control makes generic the followi jurisdictions. The log of data restoration efforts sh of the restored data, and the data that were restor
A.11.4	Protecting data on storage media leaving the premises	YES	N/A	PII on media leaving the organization's premises sh and should not be accessible to anyone other than concerned).
A.11.5	Use of unencrypted portable storage media and devices	YES	N/A	Portable physical media and portable devices that except where it is unavoidable, and any use of such documented. By Policy removable media is only all then the drive would need to be encrypted.
A.11.6	Encryption of PII transmitted over public data-transmission networks	YES	N/A	PII that is transmitted over public data-transmissio transmission. **Public cloud PII protection implementation guid** In some cases, e.g. the exchange of e-mail, the inh network systems can require that some header or Where multiple service providers are involved in pr of the cloud computing reference architecture, the this guidance.
A.11.7	Secure disposal of hardcopy materials	YES	N/A	Where hardcopy materials are destroyed, they sho such as cross-cutting, shredding, incinerating, pul
A.11.8	Unique use of user IDs	YES	N/A	If more than one individual has access to stored PI identification, authentication and authorization pur
A.11.9	Records of authorized users	YES	N/A	An up-to-date record of the users or profiles of us system should be maintained. **Public cloud PII protection implementation guid**

				A user profile should be maintained for all users wh processor. The profile of a user comprises the set

A.11.10	User ID management	YES	N/A	De-activated or expired user IDs should not be gra **Public cloud PII protection implementation guid** In the context of the whole cloud computing refere be responsible for some or all aspects of user ID m control.
A.11.11	Contract measures	YES	N/A	Contracts between the cloud service customer and minimum technical and organizational measures to arrangements are in place and that data are not processed for an controller. Such measures should not be subject to processor. **Public cloud PII protection implementation guid** Information security and PII protection obligations directly from applicable law. Where this is not the c public cloud PII processor should be covered in the together with the controls in ISO/IEC 27002, are int assist in entering into an information processing co The public cloud PII processor should inform a pro into a contract, about the aspects of its services m processor should be transparent about its capabili However, it is ultimately the cloud service custome implemented by the public cloud PII processor me
A.11.12	Sub-contracted PII processing	YES	N/A	Contracts between the public cloud PII processor a specify minimum technical and organizational mea PII protection obligations of the public cloud PII pro unilateral reduction by the sub-contractor. **Public cloud PII protection implementation guid** The use of sub-contractors to store backup copies

A.11.13	Access to data on pre-used data storage space	YES	N/A	The public cloud PII processor should ensure that cloud service customer, any data previously residi

Public cloud PII protection implementation guid

On deletion by a cloud service user of data held in mean that explicit erasure of those data is impracti able to read the data. Such risk should be avoided guidance is especially appropriate for dealing with as an example, some cloud infrastructure, platform service user attempts to read storage space which

A.12	Privacy Compliance	Applicability (Yes/No)	Justification for non-applicability	Control
A.12.1	Geographical location of PII	YES	N/A	The public cloud PII processor should specify and be stored. **Public cloud PII protection implementation guid** The identities of the countries where PII can possib service customers. The identities of the countries processing should be included. Where specific contractual ag data, such as Model Contract Clauses, Binding Co

ISO 27017 Cloud Security

ANNEX A				
Control ID	**Control Name**	**Applicability (Yes/No)**	**Justification for non-applicability**	**Control**
CLD.6.3	Relationship between cloud service customer and cloud service provider			Objective: To clarify the relationship regarding sha service customer and the cloud service provider fo
CLD.6.3.1	Shared roles and responsibilities within a cloud computing environment	YES	N/A	Control Responsibilities for shared information security rol allocated to identified parties, documented, communicated and impleme cloud service provider.

				Implementation guidance for cloud services Cloud service customer

				policies and procedures in accordance with its use services, and make cloud service users aware of tl responsibilities in the use of the cloud service. (note: check TOS -shared responsibility matrix Cloud service provider The cloud service provider should document and c its information security capabilities, roles, and resp for the use of its cloud service, along with the infor security roles and responsibilities for which the clc customer would need to implement and manage a use of the cloud service. Other Information for cloud services: In cloud computing, roles and responsibilities are t service customer and employees of the cloud service provider. The alloc consideration the cloud service customer data and the cloud service service provider is a custodian.
CLD.8.1	Responsibility for assets	**Applicability (Yes/No)**	**Justification for non-applicability**	The objective specified in clause 8.1 of ISO/IEC 27(
CLD.8.1.5	Removal of cloud service customer assets	YES	N/A	Control Assets of the cloud service customer that are on tl removed, and returned if necessary, in a timely ma agreement. Implementation guidance for cloud services Cloud service customer

				The cloud service customer should request a docu description of the termination of service process tl
				service provider's systems. The description shoulc the termination of service, which should occur in a Cloud service provider The cloud service provider should provide informa the arrangements for the return and removal of an service customer's assets upon termination of the the use of a cloud service. The asset return and re agreement and should be performed in a timely ma assets to be returned and removed.
CLD.9.5	Access control of cloud service customer data in shared virtual environment	**Applicability (Yes/No)**	**Justification for non-applicability**	Objective: To mitigate information security risks wl computing.
CLD.9.5.1	Segregation in virtual computing environments	YES	N/A	Control A cloud service customer's virtual environment rur other cloud service customers and unauthorized persons. Implementation guidance for cloud services Cloud service customer (no additional implementation guidance) Cloud service provider The cloud service provider should enforce appropı segregation of cloud service customer data, virtua applications, operating systems, storage, and netv – the separation of resources used by cloud servic in multi-tenant environments; – the separation of the cloud service provider's int administration from resources used by cloud servi customers. Where the cloud service involves multi-tenancy, th service provider should implement information sec

				controls to ensure appropriate isolation of resourc different tenants.
				the cloud services offered by the cloud service pro Other information for cloud services Implementation of the logical segregation depends virtualization: – Network and storage configurations can be virtu provides a virtual environment (e.g., a virtual operating syster customers in software virtualized environments can be desigr of the software. – When a cloud service customer's information is s "meta- data table" of the cloud service, segregation of inf be implemented with access control on the "meta- guidance given in "ISO/IEC 27040, Information tec can apply to the cloud computing environment.
CLD.9.5.2	Virtual machine hardening			Control Virtual machines in a cloud computing environmen Implementation guidance for cloud services Cloud service customer Cloud service provider When configuring virtual machines, cloud service c ensure that appropriate aspects are hardened (e.g., only those ports, protocols and appropriate technical measures are in place (e.g., anti-malware, logging) for each virtual
CLD.12.1	Operational procedures and responsibilities	**Applicability: Yes**	**Justification for non-applicability: N/A**	The objective specified in clause 12.1 of ISO/IEC 27
CLD.12.1.5	Administrator's operational security	YES	N/A	Control Procedures for administrative operations of a clou documented and

				monitored. Implementation guidance for cloud services

				The cloud service customer should document proc critical operations where a failure can cause unrec damage to assets in the cloud computing environn Examples of the critical operations are: – installation, changes, and deletion of virtualized such as servers, networks and storage; – termination procedures for cloud service usage; – backup and restoration. The document should specify that a supervisor sh these operations. Cloud service provider The cloud service provider should provide docume about the critical operations and procedures to clc customers who require it. Other information for cloud services Cloud computing has the benefit of rapid provisior service. These operations are often carried out by administrators from the cl provider. Because human intervention in these critical operations can cause mechanisms to safeguard the operations should be considered and, if needed, b incidents include erasing or shutting down a large number of virtual
CLD.12.4	**Logging and monitoring**	**Applicability: (Yes/No)**	**Justification for applicability/non-applicability**	The objective specified in clause 12.4 of ISO/IEC 2
CLD.12.4.5	Monitoring of Cloud Services	YES	N/A	Control The cloud service customer should have the capal of the cloud services that the cloud service customer uses.

				Implementation guidance for cloud services Cloud service customer
				the cloud service provider of the service monitorin available for each cloud service. Cloud service provider The cloud service provider should provide capabili enable the cloud service customer to monitor spec relevant to the cloud service customer, of the oper cloud services. For example, to monitor and detec service is being used as a platform to attack other sensitive data is being leaked from the cloud servi Appropriate access controls should secure the use monitoring capabilities. The capabilities should pro only to information about the cloud service custom cloud service instances. The cloud service provide monitoring capabilities to the cloud service custon with the event logs described in clause 12.4.1 and
CLD.13.1	Network security Management	**Applicability: Yes**	**Justification for applicability/non-applicability: N/A**	The objective specified in clause 13.1 of ISO/IEC 27
CLD.13.1.4	Alignment of security management for virtual and physical networks	YES	N/A	Control Upon configuration of virtual networks, consistenc networks should be verified based on the cloud service provider's netv Implementation guidance for cloud services Cloud service customer (no additional implementation guidance Cloud service provider

				The cloud service provider should define and docu information security policy for the configuration of
				that the virtual network configuration matches the security policy regardless of the means used to cr configuration. Other information for cloud services In a cloud computing environment built on virtualiz on virtual infrastructure on a physical network. In such envir cause system outages or defective access control. NOTE – Depending or

Document Classification: INTERNRAL

Version History

Version	Published	Author	Description
1.7	Dec 4, 2022	Susan Phillips	Migrated from 2013 version of ISO27001 to 2022 versioning
1.8	Feb 14, 2023	Susan Phillips	2023 Annual Review and Approval
1.9	Dec 1, 2023	Caleb Hill	Privacy Updates
2.0	Jan 28, 2024	Susan Phillips	2024 Annual Review, update and approval

+ Add label


Be the first to add a reaction